Q1.
Quelle est la différence entre assurer la sécurité et assuré la sûreté d’un système d’informations ?

R1.
Sécurité :
- Protection contre les actions malveillantes volontaires. Non quantifiable statiquement, mais il est possible **d’évaluer en amont le niveau de risque et les impacts.**

Sûreté :
- Protection contre les dysfonctionnements et accidents involontaires. Quantifiable statistiquement.

Q2.
Quelle sont les quatres principaux critères de l’évaluation de la sécurité d’un S.I ?

R2.
- **Confidentialité**
- **Intégrité**
- **Disponibilité**
- **Authenticité**

Q3.
Donner le niveau (bas, moyen, haut) nécessaire à assurer pour chacun des principaux critères de sécurité des S.I dans les deux cas suivants :
- Un système d’édition d’emploi de temps
- Un système de vente en ligne

R3.
Pour un système d'édition d'emploi de temps :
1. **Confidentialité** : Moyen (pour protéger les informations des employés)
2. **Intégrité** : Haut (pour éviter les erreurs dans les horaires)
3. **Disponibilité** : Haut (pour un accès constant)
4. **Authenticité** : Moyen à Haut (pour garantir l'identité des utilisateurs)

Pour un système de vente en ligne :
1. **Confidentialité** : Haut (pour protéger les données des clients)
2. **Intégrité** : Haut (pour des transactions précises)
3. **Disponibilité** : Haut (pour une accessibilité constante)
4. **Authenticité** : Haut (pour éviter la fraude)

Q4.
Quelle est la différence entre une attaque ciblé et une attaque non ciblé ? Donner des exemples de chaque types d'attaques

R4.
Attaque non Ciblé :
- Attaques contre des proies aleatoires.
- Utilisation de maliciels (malware).
- Vecteurs de propagation : e-mail, sites web contamines, SMS, etc.

Attaque Ciblé:
-Attaque contre une cible identifiée afin de compromettre une propriété de base de la sécurité de systèmes (intégrité, disponibilite, confidentialité, ...,etc.)

Q5.
Qu'est ce que l'hameçonnage (phishing) ? Donner quelques critères pour repérer un courriel d'hameçonnage.

R5.
Courrier dont l'expediteur se fait généralement passée pour un organisme demandant au destinataire de fournir des informations confidentielles
- Quelques critères pour repérer un courriel d'hameçonnage :

1. **Demandes d'infos sensibles :** Évitez de partager des informations confidentielles.
2. **Liens suspects :** Ne cliquez pas sur des liens douteux.
3. **Erreurs linguistiques :** Soyez vigilant face aux fautes d'orthographe ou de grammaire.
4. **Urgence injustifiée :** Méfiez-vous des demandes pressantes ou menaçantes.
5. **Adresses d'expédition suspectes :** Vérifiez attentivement les adresses e-mail des expéditeurs.

Q6.
Quelle est la différence entre un virus informatique, un vers informatique, un wabbit ?

R6.
- **Virus informatique :** Un programme capable de se répliquer et conçu pour se propager d'un ordinateur à un autre en s'insérant dans des logiciels légitimes, appelés **hôtes**.
- **Vers informatique :** Un programme capable de se répliquer et conçu pour se propager d'une manière autonome à travers les réseaux.
- **Wabbit :** Un programme capable de se répliquer mais ne possède pas la capacité de propagation dans les réseaux.

Q7.
Qu'est ce qu'une attaque de Déni de Service ? Donner un exemple concret

R7.

C’est une attaque qui permet de rendre le service lent ou indisponible.
- Exemple: Attack **TCP SYN flood** qui permet d’envoyer des paquets **TCP SYN** en masse afin de saturer la connexion.

Q8.

Le protocole IPv6 ne permet plus d’avoir un mode de diffusion don’t la portée dépasse un réseau local. Expliquer l’intérêt de cette mesure d’un point de vue de sécurité des réseaux.

R8.

Limiter la portée des diffusions multicast à un réseau local en IPv6 réduit la surface d'attaque, empêche les attaques DDoS étendues, offre un meilleur contrôle du trafic réseau et protège les données sensibles en empêchant leur diffusion au-delà du réseau local.

Q9.

Des experts de sécurité proclament que les objets connectés représentent aujourd’hui une grande vulnérabilité pour les S.I. Discuter la véracité de cette proposition.

R9.

Les objets connectés présentent une grande vulnérabilité pour les systèmes d'information car ils sont souvent conçus sans suffisamment de mesures de sécurité, ce qui les rend faciles à pirater. Cela peut conduire à des risques de divulgation de données sensibles et de perturbation des opérations.

1. Sécurité minimale : Les objets connectés manquent souvent de sécurité.
2. Mises à jour difficiles : Les correctifs de sécurité sont souvent compliqués à installer.
3. Faible authentification : Certains dispositifs ont des mesures d'authentification faibles.
4. Multiplication des vulnérabilités : Chaque objet connecté est une porte d'entrée potentielle pour les attaquants.
5. Conséquences sérieuses : Les compromissions peuvent causer des fuites de données et des interruptions de service.

Q10.

Dans le domaine de la cybersécurité, qu’est ce qu’un **O.I.V** ? Donner des exemples.

R10.

O.I.V = Opérateur d’Importance Vitale
Exemple :
- Secteurs étatiques : civil, justice, militaire….
- Secteurs de la protection des citoyens : santé, gestion de l’eau, alimention
- Secteurs de la vie économique et sociale : énergie, communication, électronique, audiovisuel, information, transports, finances, industrie.

Q12.

Quelle est la différence entre un pare-feu et un IDS ? Donner des exemples de chaque types de systèmes.

R12.

Pare-feu : Un équipement, logiciel ou matériel, chargé de contrôler l'échange de paquets entre le réseau protégé et l'internet.
IDS (Système de détection d'intrusions) : Un équipement, logiciel ou matériel, qui automatise le processus d'analyse des événements d'un ordinateur/réseau pour y détecter des signes de problèmes de sécurité.

IDS détecte mais n'empêche pas les attaques.
Pare-feu détecte et empêche les attaques

Exemple : pare-feu logiciel (iptables sur les systèmes linux)

Q13.

Donner un exemple détaillé d'une attaque réseau par réflexion

R13.

Dans une attaque par réflexion :

1. L'attaquant falsifie l'adresse IP source des paquets qu'il envoie.
2. Il envoie des requêtes à des serveurs mal configurés, utilisant l'adresse IP de la cible comme source.
3. Les serveurs mal configurés répondent à la cible avec des réponses amplifiées.
4. La cible est submergée par le volume massif de trafic, la rendant indisponible pour les utilisateurs légitimes.

Q14.

Un administrateur système décide d'interdir l'envoi vers l'extérieur de son réseau tout paquet ICMP. Est ce une bonne décision ? argumenter votre réponse

R14.

Bloquer les paquets ICMP sortants peut renforcer la sécurité en réduisant la surface d'attaque et en préservant la confidentialité du réseau. Cependant, cela peut aussi compliquer le dépannage des problèmes de connectivité et perturber le fonctionnement de certains protocoles et applications qui en dépendent. La décision dépend des besoins spécifiques du réseau et des compromis entre sécurité, performance et compatibilité.

Q15.

L'utilisation du protocole TCP assure un bon niveau de sécurité de l'échange de l'information. Discuter la véracité de cette proposition.

R15.

Le protocole TCP assure une transmission fiable des données mais ne garantit pas leur sécurité. Il ne chiffre pas les données en transit ni n'authentifie les parties communicantes. Des mesures supplémentaires sont nécessaires pour assurer la sécurité, comme le chiffrement et l'authentification.

Q17.

On considère un routeur/pare-feu qui relie un réseau 192.168.1.0/24 à l'internet. Toutes les machines de ce réseau ont un accés sans restriction à tous les services sauf la machine 192.168.1.10 qui doit avoir un accés aux services **http seulement** (**ports 80 443**). Pour mettre en place cette politique la table de filtrage du pare-feu est configurée comme suit :

- **Si** @IP source = 192.168.1.10 & segment TCP & dport != 80 **Alors** Refuser.

- **Si** @IP source = 192.168.1.10 & segment TCP & dport != 443 **Alors** Refuser.

- **Si** @IP source != 192.168.1.10 **Alors** Accepter.

Q17.1

Est ce que la configuration proposée est conforme au cahier des charges ? Justifier votre réponse et proposer une correction si nécessaire.

R17.1

Non, le cahier des charges n'est pas respecté car la politique par défaut (**FORWARD, INPUT, OUTPUT**) n'est pas respecté.

- **Correction** :

- **Si** @IP source = 192.168.1.10 & segment TCP & dport = 80 **Alors Accepter**

- **Si** @IP source = 192.168.1.10 & segment TCP & dport = 443 **Alors Accepter**

- **Si** @IP source != 192.168.1.10 **Alors Accepter.**

- **Rejeter tout**

Q17.2

Proposer une implémentation en utilisant l'application **iptables.**

R17.2

- **iptables -P FORWARD DROP**
- **iptables -P INPUT DROP**
- **iptables -P OUTPUT DROP**

- **iptables -A FORWARD** -s 192.168.1.10 -p tcp -dport 80 -j **ACCEPT**

- **iptables -A FORWARD** -s 192.168.1.10 -p tcp -dport 443 -j **ACCEPT**

- iptables -A FORWARD -s 192.168.1.10 -p tcp -sport 80 -j **ACCEPT**

- iptables -A FORWARD -s 192.168.1.10 -j **drop**

- iptables -A FORWARD -s 192.168.1.0/24 -j ACCEPT

- iptables -A FORWARD -d 192.168.1.0/24 -j ACCEPT

Q18. On considère l'ensemble des règles suivante d'un pare-feu pour le filtrage du trafic sortant du réseau protégé don't l'adresse est 60.47.0.0/16 :
1 Si @IP srouce != 60.47.*.* **Alors Refuser**
2 Si type ICMP=Echo-Request **Alors Accepter**
3 Si ICMP **Alors Refuser**
4 Si TCP RST **Alors Refuser**
5 Si @IP source=60.47.3.9 & sport **appartient** {80, 443} **Alors Accepter**
6 Si TCP & sport **appartient** [0, 49151] **Alors Refuser**
7 Si UDP & sport **appartient** [0, 49151] **Alors Refuser**
8 Si TCP & sport **appartient** [49152, 65536] **Alors Accepter**
9 Si UDP & sport **appartient** [49152, 65536] **Alors Accepter**
10 Refuser tout

Q18.1 Justifier chacune des règles données ci-avant.

Q18.2 Certaines règles sont redondantes, lequelles ?

Q18.3 Modifier le pare-feu de sorte à accepter les requêtes **DNS** à **destination** de **60.47.3.4** et le **trafic ssh** nécessaire à l'administration du serveur.

Q18.4 Donner la configuration du pare-feu, après modifications apportées dans les deux précédentes questions, en utilisant la syntaxe **iptables**.

R18.1

Voici un résumé des règles du pare-feu :

1. Bloquer tout le trafic sortant n'appartenant pas au réseau protégé.
2. Autoriser les requêtes de type ping (Echo-Request ICMP).
3. Bloquer tous les autres types de paquets ICMP.
4. Bloquer les paquets TCP avec le flag RST.
5. Autoriser le trafic provenant d'une adresse IP spécifique (60.47.3.9) avec des ports source spécifiques (80 ou 443).
6. Bloquer les ports TCP bien connus et enregistrés, permettant uniquement les ports éphémères.
7. Bloquer les ports UDP bien connus et enregistrés, permettant uniquement les ports éphémères.
8. Autoriser le trafic sortant provenant de ports éphémères TCP.
9. Autoriser le trafic sortant provenant de ports éphémères UDP.

10. Bloquer tout autre trafic sortant qui ne correspond à aucune des règles précédentes.

R18.2

1 Si @IP srouce != 60.47.*.* **Alors Refuser**
2 Si type ICMP=Echo-Request **Alors Accepter**
4 Si TCP RST **Alors Refuser**
5 Si @IP source=60.47.3.9 & sport **appartient** {80, 443} **Alors Accepter**
8 Si TCP & sport **appartient** [49152, 65536] **Alors Accepter**
9 Si UDP & sport **appartient** [49152, 65536] **Alors Accepter**
10 Refuser tout

R18.3

Si UDP & @IP destination=60.47.3.4 & Dport=53 Alors Accepter

Si TCP & @IP destination=60.47.3.4 & Dport=22 Alors Accepter

R18.4

- iptables -P **FORWARD** DROP
- iptables -P **OUTPUT** DROP
- iptables -P **INPUT** DROP

- iptables -A **OUTPUT -s** 60.47.*.* -j **ACCEPT**

- iptables -A **OUTPUT** -p icmp **--icmp-type echo-reques**t -j **ACCEPT**
- iptables -A **OUTPUT** -p tcp **--tcp-flags RST** -j **REJECT**

- iptables -A **OUTPUT** -s 60.47.3.9 **-m multiport** -sport 80, 443 -j **ACCEPT**
- iptables -A **OUTPUT** -p tcp **-m multiport** -sport **49152:65536** -j **ACCEPT**
- iptables -A **OUTPUT** -p udp **-m multiport** -sport **49152:65536** -j **ACCEPT**

- iptables -A **OUTPUT** -d 60.47.3.4 -p udp -dport 53 -j **ACCEPT**
- iptables -A **OUTPUT** -d 60.47.3.4 -p tcp -dport 22 -j **ACCEPT**

DEFINITION :

Vulnérabilité : Faiblesse au niveau d'un bien (au niveau de la conception, de la realisation, de l'installation, de la configuration ou de l'utilisation du bien).

Menace : Cause potentielle d’un incident, qui pourrait entrainer des dommages sur un bien si cette menace se concretisait.

Attaque : Une action qui vise a compromettre la sécurité d’un système.

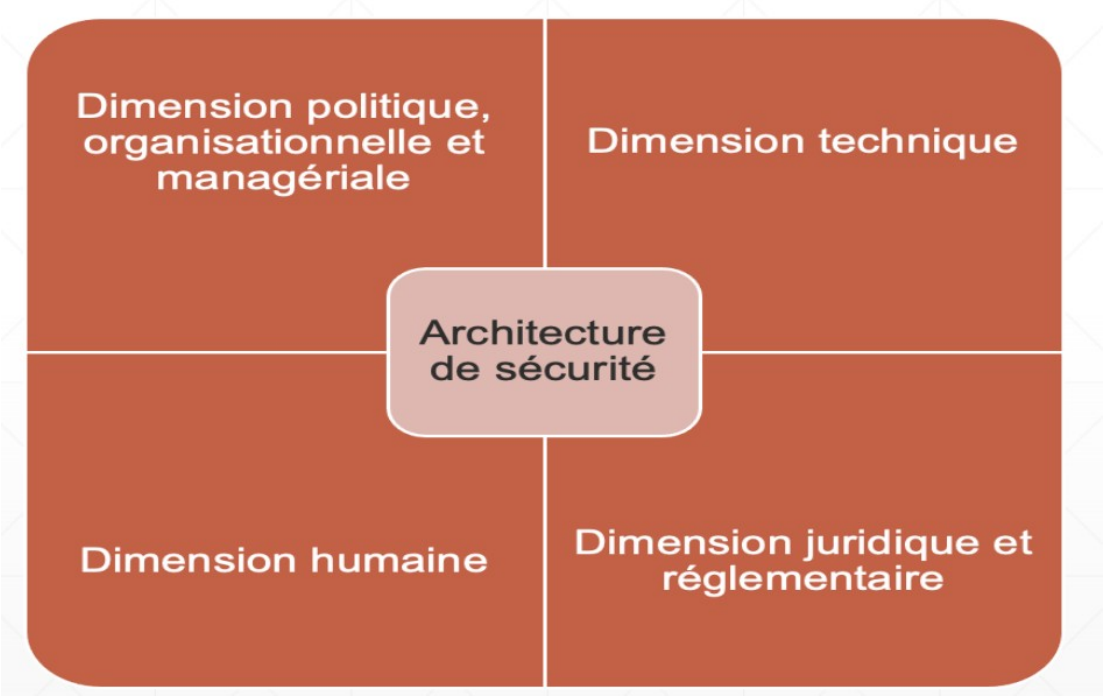
Intrusion : Prise de controle, partielle ou totale d’un système distant.

Usurpation : (spoofing) la prise d’identité d’autrui (utilisateur ou système) afin de gagner une accés illégitime à un système.

- Virus informatique : Un programme capable de se répliquer et conçu pour se propager d’un ordinateur à un autre en s’insérant dans des logiciels légitimes, appelés **hôtes**.

- Vers informatique : Un programme capable de se répliquer et conçu pour se propager d’une manière autonome à travers les réseaux.

- Wabbit : Un programme capable de se répliquer mais ne possède pas la capacité de propagation dans les réseaux.



LES 4 PRINCIPAUX CRITERES D'UN S.I

OBJECTIFS D'UN SYSTÈME DE SÉCURITÉ

- **Confidentialité**
  Seuls les utilisateurs ayant droit ont accès aux données
- **Intégrité**
  Seuls les utilisateurs ayant droit peuvent modifier les données
- **Disponibilité**
  Garantir l'accessibilité des données aux utilisateurs ayant-droit
- **Authenticité**
  Garantir d'avoir l'identité exacte de la source d'une action
- **Non-répudiation**
  Garantir que le destinataire (resp. émetteur) d'un message ne peut pas prétendre ne pas l'avoir reçu (resp. envoyé).

LE CYCLE PPR

- **PPR** : Planification → Protection → Réaction
- **Planification** : Analyses des menaces (montant des dommages, Probabilité, coût de la protection, priorité) → règles & règlement
- **Protection** : Sélection et installation des outils, mise à jour, audit (test et mise à l'épreuve).
- **Réaction** : Détection de l'incident, procédure de réaction, restauration et sanction, **retour d'expérience** et réparation de failles.

- **Attaques passives**
  - Interception
  - Ecoute
  - Espionnage
  - Cartographie
- **Attaques actives**
  - Modification
  - Fabrication
  - Interruption
  - Destruction

- Cheval de Troie : Un maliciels qui prend l'apparence d'un logiciel légitime.
- Vecteur de propagation: sites de téléchargement !
- Souvent employé pour mettre en place d'autres maliciels : virus, vers, trappes, logiciels d'espionnage, etc.

- Trappe : un programme installé sur la machine victime et qui se connecte à la machine de l'attaquant pour lui donner un accès à la machine infectée.
- Installé par un développeur d'une application, ou par un autre maliciels (ex. cheval de Troie).

- Logiciel espion : logiciel malveillant qui s'installe dans un ordinateur dans le but de collecter et transférer des informations sur l'environnement dans lequel il s'est installé, très souvent sans que l'utilisateur n'en ait connaissance.
- `Keylogger` : Matériel ou logiciel qui enregistre les touches frappées sur le clavier et les transmettre via les réseaux ou via des ondes électromagnétiques.

MALICIELS : ATTAQUES PAR-E-MAIL



- **Hoax** (Canular) : Courrier électronique incitant le destinataire à retransmettre le message à ses contacts sous divers prétextes (bon sentiments, alarmes, légendes urbaines, etc.)

  `http://www.hoaxbuster.com/`
- **Spam** : courriers non sollicité qui encombrent le réseau.
- **hameçonnage** (phishing) : courrier dont l'expéditeur se fait généralement passé pour un organisme demandant au destinataire de fournir des informations confidentielles

Attaques ciblées: buts 1/2

- **Attaques des systèmes**
  - **Interruption** : réduire la disponibilité d'un système
    Déni de service (DoS)
  - **Cartographie** : Reconnaitre les machines et les services actifs et les versions des systèmes d'exploitation
    Balayage des machines et des ports
  - **Modification de données**
    DNS poisoning, ARP poisoning

Attaques ciblées: buts 2/2

- **Attaques des communications**
  - **Interception de messages**
    Ecoute & analyse de traffic (snifing)
  - **Modification, fabrication de messages**
    Usurpation d'adresses IP
  - **Vol de sessions**

Attaques : Attaques DoS simples

Ping de la mort

- Envoyer un paquet `ping` malformé (taille > taille max de 65 535)
- La plupart des systèmes jusqu'au 1998, ne peuvent pas traiter un tel paquet

LAND

- Envoyer un paquet `SYN` malformé : mêmes adresses IP sources et destinations et mêmes ports
- Conséquence: blocage du système visé

Teardrops

- Envoyer des fragments IP avec des informations erronées de décalage (offsets).

Attaques par saturation

Rafales de SYN

- Envoyer une rafale de paquets `SYN`.
- La victime alloue une partie de ses ressources à chaque demande : on assiste à à un phénomène de saturation, voire de pannes

Rafales d'Echo-Reply

- Envoyer un message `echo-request` avec @Source = @Victime, @Dest: mode diffusion
- Si la victime est reliée à un routeur opérant en mode diffusion, tous les ordinateurs du réseau répondent à la victime par des `echo-reply`.

ARP poisoning

- Envoyer un paquet ARP avec @MAC: pirate et @IP: @victime
- Le trafic vers la victime sera d'abords adressée au pirate tant que la victime n'as pas communiqué avec la machine cible !
- Mise à jours sans relâche de la table ARP.

Type de balayage	Syntaxe	mode root exigé
TCP SYN	`-sS`	OUI
TCP connect	`-sT`	NON
FIN	`-sF`	OUI
XMAS Tree	`-sX`	OUI
NULL	`-sN`	OUI
PING	`-sP`	NON
Détection de version	`-sV`	NON
UDP	`-sU`	OUI
IP	`-sO`	OUI
Acquittement	`-sA`	OUI
Idle	`-sI`	OUI

Pare-feux

Définition

Un équipement, logiciel ou matériel, chargé de contrôler l'échange de paquets entre le réseau protégé et l'Internet.

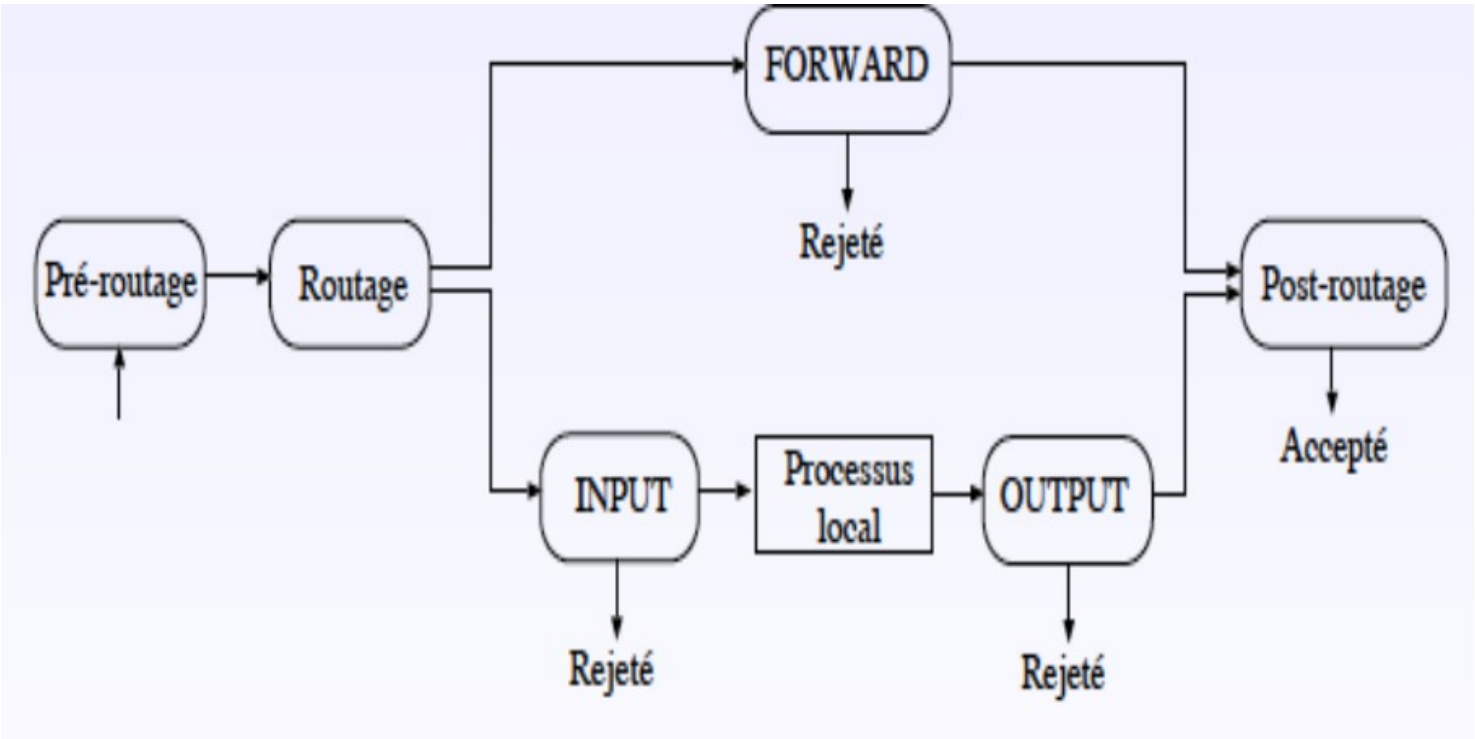
Fonctions

- **Contrôle** : Gérer les connexions sortantes à partir du réseau local.
- **Sécurité** : Protéger le réseau interne des intrusions venant de l'extérieur.
- **Vigilance** : Surveiller/tracer le trafic entre le réseau local et internet.

Pare-feux : types

- Pare-feu au niveau réseau
  Filtrage des paquets
  Transparente pour les utilisateurs
- Pare-feu au niveau applicatif
  Proxy dédié à une application : proxy web, proxy ftp, etc.
  Possibilité d'interpréter le contenu du trafic
- Pare-feu des applications
  Restrictions au niveau des différentes applications `/etc/ftpaccess` *pour ftp*

CHAINE DE CONTROLE



CIRCUIT DES PAQUETS GÉNÉRÉS PAR LA MACHINE

1. raw OUTPUT
2. mangle OUTPUT
3. nat OUTPUT
4. filter OUTPUT
5. mangle POSTROUTING
6. nat POSTROUTING

CIRCUIT DES PAQUETS EN TRANSIT

1. raw PREROUTING
2. mangle PREROUTING
3. nat PREROUTING
4. mangle FORWARD
5. filter FORWARD
6. mangle POSTROUTING
7. nat POSTROUTING

IPTABLES : CRÉATION DE CHAINES

- **-N** : création d'une chaîne
- `iptables -N LOGACCEPT`
- `iptables -A LOGACCEPT -j LOG --log-prefix "LOGACCEPT : "`
- `iptables -A LOGACCEPT -j ACCEPT`

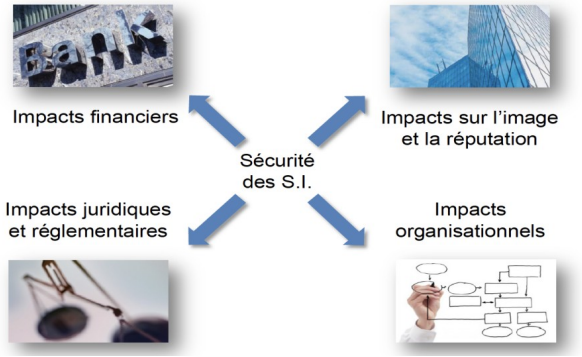
IPTABLES: NAT

- `iptables -t nat -A POSTROUTING -o eth1 -s 192.168.0.0/24 -j MASQUERADE`
- Association entre toutes les adresses privées du sous-réseau 192.168.0.0/24 avec l'interface eth1.
- `iptables -t nat -A POSTROUTING -o eth2 -s 192.168.1.0/24 -j MASQUERADE`
- Association entre toutes les adresses privées du sous-réseau 192.168.1.0/24 avec l'interface eth2.
- `iptables -t nat -A PREROUTING -p tcp -i eth0 -d 140.77.13.2 -dport 80 -sport 1024:65535 -j DNAT -to 192.168.0.200:8080`
- Transférer les connexions sur le port 80 de l'adresse 140.77.13.2 sur la machine ayant l'adresse privée 192.168.0.200 sur le port 8080

FILTRAGE DYNAMIQUE

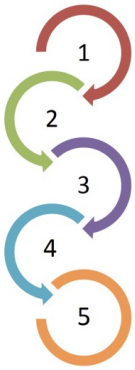
- Suivi des connexions disponible (conntrack)
- 4 états possibles d'une connexion : NEW, ESTABLISHED, RELATED, INVALID
- `iptables -A OUTPUT -o eth0 -m state -state ESTABLISHED,RELATED -j ACCEPT`
- Autoriser tous les paquets émis par le routeur concernant des connexions déjà établies.

ENJEUX DE LA SÉCURITÉ DES S.I.



ENJEUX DE LA SÉCURITÉ DES S.I.

Une majorité des actes de délinquance réalisés sur Internet sont commis par des groupes criminels organisés, professionnels et impliquant de nombreux acteurs



des groupes spécialisés dans le **développement de programmes malveillants** et virus informatiques

des groupes en charge de l'**exploitation et de la commercialisation** de services permettant de réaliser des attaques informatiques

un ou plusieurs **hébergeurs** qui stockent les contenus malveillants, soit des hébergeurs malhonnêtes soit des hébergeurs victimes eux-mêmes d'une attaque et dont les serveurs sont contrôlés par des pirates

des groupes en charge de la **vente des données volées**, et principalement des données de carte bancaire

des **intermédiaires financiers** pour collecter l'argent qui s'appuient généralement sur des réseaux de **mules**

IMPACTS SUR LES INFRASTRUCTURES CRITIQUES

- Infrastructures critiques = un ensemble d'organisations parmi les secteurs d'activité suivants, et que l'État français considère comme étant tellement critiques pour la nation que des mesures de sécurité particulières doivent s'appliquer
  - Secteurs étatiques : civil, justice, militaire…
  - Secteurs de la protection des citoyens : santé, gestion de l'eau, alimentation
  - Secteurs de la vie économique et sociale : énergie, communication, électronique, audiovisuel, information, transports, finances, industrie.
- Ces organisations sont classées comme **Opérateur d'Importance Vitale (OIV).** La liste exacte est classifiée (donc non disponible au public).

SÛRETÉ OU SÉCURITÉ ?

Sûreté

Protection contre les dysfonctionnements et accidents involontaires

Exemple de risque : saturation d'un point d'accès, panne d'un disque, erreur d'exécution, etc.

Quantifiable statistiquement (ex. : la durée de vie moyenne d'un disque est de X milliers d'heures)

Parades : sauvegarde, dimensionnement, redondance des équipements…

Sécurité

Protection contre les actions malveillantes volontaires

Exemple de risque : blocage d'un service, modification d'informations, vol d'information

Non quantifiable statistiquement, mais il est possible d'évaluer en amont le niveau du risque et les impacts

Parades : contrôle d'accès, veille sécurité, correctifs, configuration renforcée, filtrage…*